

Datasec / HPSM — Sitting Pack

Monday 2026-08-17 · prepared by Wednesday for Kam's second screen · sources: D01 v0.5, sessions 22–24, the decision queue, the deck (v1, 43 slides) — every figure re-derived from the SOW/PRD/CT/GTM/MSA .docx extractions, not from summaries. SOW-01 is **Draft v1.0, unsigned; no PO, no notice to proceed**.

0 · BLUF — what today has to produce

DECISION — ready to take as-is D-26, the structure: adopt option (i) with three amendments — rename section 5 to “*Security Operating Model, Governance & Compliance Readiness*”; restore Compliance weight **10% → 15%** (take the 5% from Hardening); give P08 (due 18 Sep) somewhere to land. Compliance was a **mis-grade, not a gap** — the grade was assigned from the GTM *price list*; the Datasec_05 template already contains a named Framework Alignment section (ISO 27001 / NIST / Essential Eight / SOC 2) and ships the mapping as output #7.

DECISION — before the room Amplify fallback (HPSM-25, premise EXPIRED): a 112-day plan started today lands **Mon 7 Dec — two days after** the Sat 5 Dec Amplify anchor. The choice is no longer “settle the date”, it is **which fallback**: slip with §6 relief · compress · re-anchor · announce-at-Amplify-then-release. Note: on a slipped NTP, **\$17 does not rebaseline** — the SOW would schedule hypercare *before* the release it supports. Price that into whichever fallback you pick.

DECISION — one sentence, deadline 21 Aug The P05 sentence: get into P05 the confirmation that “*deterministic*” = *reproducible for a given question-set and weights version*. It is the split that protects M3 (**20% / A\$150,000**) — engine determinism (testable today) vs content correctness (needs P05). Wording is drafted in the structure review §3.5.

DECISION K5 — six sessions of analysis on ONE drive, outside version control. Recommendation: **(b) drive-level backup now** (reversible, no NDA call needed), then (a)/(c) deliberately.

QUESTION — 5 minutes, highest value open item E14 — does an executed CSPA exist, and can we read it? It outranks the SOW at §3 rank 1 and carries warranty, liability, support and IP. (a) exists+shareable → four threads unblock · (b) exists+unshareable → mark them assumption-based · (c) never executed → itself a finding.

QUESTION — take into the room M6 naming/mapping: three of the four contracted AI assistants (Opportunity / Proposal / QBR) appear **nowhere in the PRD** under their contracted names, and PRD identifiers AI-001...AI-020 resolve to *assessment* tests, 5 of 5 — so an M6 evidence pack built from the PRD’s own numbering **passes while proving the wrong thing (10% / A\$75,000)**. A criteria proposal exists (HPSM-29, 36/36 citations machine-checked); accepting it adds no scope.

CARRY IN YOUR HEAD The §14 bundle (X1–X4: arithmetic A\$787,500 vs stated A\$750,000, and “deterministic” dropped from M3’s trigger wording) + X5 (SOW §3 binds Plan v2, §14 pays v3’s 25%/A\$187,500 on signature) + X6 (four of our own CT §18 protections missing from SOW-01). Ten minutes of corrections — they ride whichever HP conversation happens first. **None raised with HP yet; external comms are yours alone.**

1 · What we have

24 sessions of pure readiness — no build, no Azure, no spend, nothing HP-facing. Everything below exists on disk and is traceable to source.

Asset	State
Corpus, fully digested	SOW-01, PRD, Commercial Terms, GTM, MSA + the 7.6 GB HP OneDrive drop + all 13 content templates. Last unread corner (the four level templates) read Saturday — it produced the two headline findings. Every zero carries a positive control.
D01 v0.5 — architecture baseline skeleton	26 decisions structured, 36 verdict slots, all empty by design — today fills them. D-26 arrives with its recommendation ready.
The Monday pack (\$1h)	Agenda · consolidated HP ask-list (29 asks, 12 prerequisites, 4 §14 defects, 20 dated content obligations) with a coverage checker that derives its universe from disk · open-questions-by-owner · structure review.
The deck	43 slides: 1–28 client-facing narrative, 29–43 internal annex behind an unmistakable red divider. Speaker notes carry delivery guidance + per-slide SOURCES lines. Opens clean in PowerPoint and LibreOffice. Client-safe build is mechanical (<code>INCLUDE_ANNEX=False</code> , output renamed) and its note-leak defect was found and gated.
Architecture, worked through	16 positions, input-only. §9 tenant isolation mapped as a four-layer contractual gate (only the query layer designed — HPSM-28 holds the layer-4 options). AI continuity cliff flagged: both in-AU chat models retire 2027-04-14 .
Board	20 open items, every one tagged <code>[KAM-...]</code> or <code>[MONDAY 08–17]</code> . The machine work is done; what remains is decisions.

HONEST CAVEAT All of it lives on one drive outside git (K5, §0 above), and the SOW's published calendar is already fiction — every date is really $T+n$ from a notice to proceed that has not been given.

2 · Gap analysis — ranked by money

2.1 · The score itself — M3, 20% / A\$150,000

THE ONE TO LEAD WITH `ControlDomainScore` is defined nowhere. PRD §9 gives $\text{WeightedScore} = \sum(\text{ControlDomainScore} \times \text{DomainWeight})$, supplies the weights — and the term occurs **exactly once in the entire five-document stack, inside the formula that consumes it** (counted with a positive control per document). Two conforming builds can return different scores for identical answers and both pass. Do **not** lead with the narrower “input mapping undefined” version — `section` and `controlDomain` are already separate fields on the PRD's Question model, so HP closes that one for free in a sentence. They have no equivalent answer to “define `ControlDomainScore`.” Resolution rides the P05 sentence (§0).

2.2 · M6's evidence pack — 10% / A\$75,000

SETTLE IT DELIBERATELY §17.1 assigns EPIC-011 the range AI-001...AI-020; all five AI-nnn rows in PRD Appendix F are *assessment-integrity* tests. Whoever assembles M6's AI acceptance evidence by the contract's own numbering assembles a complete-looking, internally-consistent, **wrong** pack — dangerous precisely because it passes. Combined with the naming gap (§0), “relevant criteria” gets settled by accident unless it is settled today. HPSM-29's proposal: seven cross-cutting criteria + one per assistant, every one traced to an already-binding clause; Partner Training Copilot deliberately excluded (§18 puts it in the 2027 expansion — including it would widen our own scope).

2.3 · M0 — the first and largest payment — 25% / A\$187,500

COMMERCIAL ITEM FOR THE BUNDLE Neither side can currently produce M0's acceptance evidence. §7.1 accepts on “SOW/funding authority, named owners, delivery plan, backlog mobilisation confirmed” — P01 unsigned, P02 (the five names) past due and unfilled, no Datasec staff named anywhere either (§11's nine roles; D-13 open five sessions). Not a drafting defect — a tracking one: every register recorded P02 as shaping *later* gates, never as the evidence for the *first*. D-13's two pod-lead names are half of M0's evidence — that is a commercial argument, not a resourcing chore. Also: **7 of 8 gates depend on a prerequisite, and all 6 paying gates do.**

2.4 · The paper stack — X1–X6

Item	What it is	Exposure
X1–X4 (§14)	Four defects in the copy HP already holds — incl. shares summing to A\$787,500 against a stated A\$750,000 total, and M3's trigger wording dropping the word “deterministic” (the word the whole scoring design rests on).	Ten minutes of corrections; unarguable; not yet raised.
X5	§3 rank 5 binds Investment Plan v2 ; §14's payment table is v3's , verbatim. v2's Gate 0 = 10% on a deliverable; §14 pays 25% on execution. Option A alone (fix the pointer) is not sufficient — CT §17's own guardrail marks 15% as minimum protection.	A\$187,500 timing swing.
X6	CT §18 — our own “Suggested SOW Clause Pack” — four of six clauses missing/half-present in SOW-01. Six of nine gates pay on acceptance and §8 sets no time limit for acceptance ; §6 gives HP day-for-day relief with no reciprocal for us.	Unbounded acceptance tail on ~A\$450k of gated payment.

FRAMING Datasec authored the CT, both plans and the SOW — say “our document” out loud; these are corrections, not accusations. Raise X1–X5 as corrections, X6 as a request, one conversation, led separately.

2.5 · Schedule & window

- **Amplify:** see §0 — the premise expired Saturday; today's start lands 7 Dec.
- **“Business day” is undefined in all four documents**, and the hypercare window crosses the Christmas shutdown — worth ~5 days. (Session 22's “4 Jan” escalation was **withdrawn** — 1 Jan was right; the inclusive CT §16 reading reproduces §17's own baseline.)
- **§17 doesn't rebaseline** while every other date does → a slipped NTP schedules hypercare before its release.
- **Security evidence (internal version):** §16 contracts *continuous* evidence twice as the mitigation for the SOW's only two Critical risks — and nothing implements it: §8.1's definition of done has no evidence

bullet, and §14 invoices M6's A\$75k on "security evidence substantially complete" **three days before the hardening week begins**. A detection-point problem, not a "one week isn't enough" problem.

- **Post-go-live:** decided three times in our own CT (\$2, \$16, \$19.6 — put to Datasec's exec) and then dropped out of SOW-01; "warranty" appears zero times. The 5% holdback releases on hypercare *commencement*. Deadline for fixing that wording: signature, not today.
- **The funding gap:** HP's own deck funds this at **US\$650k**; SOW-01 prices A\$750,000 $\approx$ US\$490k. Changes negotiating posture — their budget line sits above our price.

2.6 · Inherited assumptions (D-12 — yours)

AWARENESS A 20–30% agentic productivity gain is baked into the 16-week estimate, unvalidated. An HP SME at 0.25–0.5 FTE with a 2-business-day SLA sits on the critical path, outside our control. PRD performance targets inherited unchallenged.

3 · The presentation — how to run it

File: 2026-08-13_HPSM-MVP_client-presentation_v1.pptx · 43 slides · **present 1–28 only**. Slides 29–43 are the internal annex behind the full-red divider — *if slide 29 is on a screen in front of a client, stop*. A genuinely client-safe file is a rebuild (INCLUDE_ANNEX=False), never a slide-delete — Part 1 notes reference the annex.

Part	Slides	The move
Open	1–2	Set the honesty frame early: draft SOW, architecture baseline unsigned, “nothing here is decided.” Name the shape: parts 1+3 are settled by the SOW, part 2 is where you want challenge, part 4 is where you want answers . 30–40 min for parts 1–4, then open detail review.
1 · Scope	3–7	Fast — they already believe it. Slide 4: say the loop out loud once (create → assess → deterministic score → findings → report); land the word DETERMINISTIC . Slide 6: don’t read the table — one observation: <i>every row is Must</i> , so scope movement = change request. Slide 7 (exclusions) buys trust — deliver as confidence, not apology.
2 · Architecture	8–15	Altitude discipline: client-technical-lead level. Slide 9 is marked RECOMMENDATION on purpose (D01 not countersigned); if challenged on “monolith” — delivery risk, not taste. Slide 10 (tenancy) is where a security-minded client pushes: the four layers are HP’s own \$9 wording — quote it. Slide 11: “the AI drafts, a person decides.” Slide 12 (residency) is OPEN by design — don’t oversell, don’t bury. Slide 14 (evidence basis) is the most commercially loaded: plays as strength only if delivered as candour. Slide 15: recommend evidence-per-milestone; do not go further in the room — the reasoning lives in the annex.
3 · Plan	16–22	Slide 17: say the footnote out loud — the published dates have already passed; the calendar is set by notice-to-proceed + prerequisites. Slide 18: show percentages, not amounts (§14’s amount column is defective — internal). Slide 20 is the most important slide in the deck: eleven inputs, each with a named critical-path effect — ask for <i>a name against each</i> ; don’t editorialise the overdue ones. Slide 22 (after go-live): a commercial slide dressed as delivery, and legitimately so — better we raise the gap than they discover it.
4 · The ask	23–28	Three items, delivered as three sentences — then stop talking . Do not add a fourth. ① P02, the five names — if you get only one thing, get this; prioritise the security SME and UAT lead (dated downstream work at weeks 1 and 11); take partial names and say which are missing. ② Architecture freeze (P03/P04) — infrastructure late-binds by design; identity and data don’t; fallback narrower ask: “does inference have to stay in Australia?” ③ Device posture (H3) — be genuinely even-handed; a “no” is workable, which is what makes it answerable. Close on the ask, not a summary.

LIKELY PUSHBACK — pre-armed answers

- “Can a partner see another partner’s customers?” → No — enforced at four layers; it’s the tenancy slide, don’t answer early.
- “Can we cut scope?” → Every workstream is Must; a cut is a named change request — better that conversation now than at UAT.
- “Why a monolith?” → Delivery risk in 16 weeks; module boundaries enforced in code; every data access through the tenancy layer.
- “How do you know the model retirement date?” → Verified on the live Azure control plane on our own subscription, not a blog.
- “Is one hardening week enough?” → Client-facing version only: capture evidence per milestone as we go (slide 15/21 recommendation). The detection-point analysis stays internal.

WHAT DONE LOOKS LIKE TODAY ① D-26 taken · ② the Amplify fallback picked · ③ the P05 sentence approved for sending · ④ names — any subset of P02’s five, plus your own two pod leads (D-13 = half of M0’s evidence) · ⑤ E14 answered a/b/c · ⑥ K5 ruled (b) · ⑦ verdict slots in D01 filled as far as the sitting reaches. I record everything and route the rest.

Wednesday · 2026-08-17 · sources: D01 v0.5 · Architecture/2026-08-16_structure-review · Monday session package §1h · HP-ask-list-CONSOLIDATED · sessions 22–24 histories · deck v1 extracted read-only. Nothing in this pack has been sent to HP; external comms remain Kam’s alone.